



**RESOLUTION BY THE CHIEF EXECUTIVE OFFICER
OF LEAN TECHNOLOGIES SAUDI FOR INFORMATION TECHNOLOGY
DATED
December 17, 2025**

I, the undersigned, being the duly appointed and acting Chief Executive Officer of Lean Technologies Saudi for Information Technology, a limited liability company registered in the Kingdom of Saudi Arabia under commercial registration no. 1010622090, having its registered address at Floor No. 1, Building No. 3403, Al Hawi Street, 7465, Hiteen District, 13516, Riyadh, Saudi Arabia (the "**Company**"), do hereby adopt the following:

WHEREAS, the Company's Information Security Function has prepared an updated version of the Information Security Strategy and Governance document ("**Document**") to incorporate certain enhancements and clarificatory items;

WHEREAS, the updated Document has been reviewed and presented to the Chief Executive Officer for approval;

NOW, THEREFORE, it is hereby resolved that:

- a) the Chief Executive Officer hereby approves and adopts the Document in the form presented to the Chief Executive Officer and attached hereto as Annex (1), with effect from the date hereof;
- b) any director and/or officer of the Company is hereby authorized to take all such further actions, and to execute all such documents, as may be necessary or desirable to carry out the foregoing resolution, including executing and delivering such documents as may be required to implement the approved updates;
- c) a copy of this resolution shall be included in the Company's corporate records and communicated to all relevant parties as required by applicable law.

Signed by **Hisham Al-Falih**

Hisham Al-Falih

Co-founder and CEO of **Lean Technologies Saudi for Information Technology**

Annex (1)

Leantech Technologies - Lean KSA

Information Security Strategy and Governance

Documents Control:

Document Name	Information Security Strategy and Governance
Document Owner	KSA CISO
Document Reviewer	KSA CISO
Document Approver	GLRCC
Entities Covered by this Document	Lean KSA
Document Classification	Confidential
Version Number	6.0
Version Date	Dec 2025
Next Scheduled Review Date	Dec 2026
Document Description	The document provides a consolidated set of application security controls that are based upon Lean security policies and standards as well as industry standards.

Version History:

Version	Type Change of	Date	Revision from previous version
1.0	Creation	October 2022	First Issue
2.0	Update	October 2023	Alignment with ISO 27001:2013
3.0	Update	October 2024	Alignment with ISO 27001:2022
4.0	Update	February 2025	Updates in order the Standard to meet SAMA CSF requirements

5.0	Update	August 2025	Updates on the template, as well as on the content of the document to fit the new template structure
6.0	Update	December 2025	Added more details on the Cyber Initiatives Roadmap

1. Purpose

The Information Security Strategy and Governance of Lean Technologies (hereinafter referred to as Lean) is a comprehensive plan that encompasses various components, including alignment with regulatory compliance, a focus on people, processes, and technology, reducing vulnerabilities, improving threat intelligence, and leveraging cutting edge tools and human expertise in the security domain for enhanced security.

2. Scope

This document applies across Lean to ensure information assets are protected, risks are managed, and regulatory compliance is met. It provides a structured approach to align security with business objectives, safeguard sensitive data, and build resilience against evolving cyber threats.

All employees or external partners are expected to comply with this document and any document that complements this document (i.e., policies, procedures, etc.), as described in section 6 of this document.

3. Definitions

Term	Definition
AI	Artificial Intelligence
APT	Advanced Persistent Threat
BCP	Business Continuity Planning
CBO	Chief Business Officer
CBUAE	Central Bank of the UAE
CCISO	Certified Chief Information Security Officer
CCO	Chief Commercial Officer
CCSP	Certified Cloud Security Professional
CEO	Chief Executive Officer
CHFI	Computer Hacking Forensic Investigator
CIO	Chief Information Officer

CISM	Certified Information Security Manager
CISSP	Certified Information Systems Security Professional
CPO	Chief Product Officer
CRFR	Cyber Resilience Fundamental Requirements
CRO	Chief Risk Officer
CSF	Cyber Security Framework
CSSLP	Certified Secure Software Lifecycle Professional
CTO	Chief Technology Officer
DAST	Dynamic Application Security Testing
DDoS	Distributed Denial of Service
DLP	Data Loss Prevention
DR	Disaster Recovery
FAQ	Frequently Asked Questions
GLRCC	Governance, Legal, Risk and Compliance Committee
IAM	Identity and Access Management
IAS	Information Assurance Standards
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
ISMS	Information Security Management System
ISO	International Organization for Standardization
IT	Information Technology
KPI	Key Performance Indicators
KRI	Key Risk Indicator
KSA	Kingdom of Saudi Arabia
MDM	Mobile Device Management
MVC	Minimum Verification Controls
NCA	National Cybersecurity Authority

OS	Operating System
OSCP	Offensive Security Certified Professional
PDPL	Personal Data Protection Law
SAMA	Saudi Arabia Monetary Authority
SAST	Static Application Security Testing
SCA	Software Composition Analysis
SDAIA	Saudi Data and Artificial Intelligence Authority
SIEM	Security Information and Event Management
SOC	Security Operations Center
SOC 2	Systems and Organization Controls 2
UAE	United Arab Emirates
WAF	Web Application Firewall
XDR	Extended Detection and Response

4. Information Security Strategy and Governance

4.1 Information Security Strategy

4.1.1 Vision and Mission

Vision - To provide a trusted and resilient cyberspace that allows Lean to become the most secure platform in the FinTech world.

Mission - To secure infrastructure, protect data and financial data, be good stewards of our clients PII and educate our employees and clients about good cyber hygiene.

4.1.2 Cybersecurity Strategy Objectives and Goals

- Ensuring data protection and privacy
- Ensuring application/SW security, infrastructure security, IT and enterprise security for Lean platforms, products and services
- Protecting Lean from cyber security incidents and breaches
- Client and employees' cyber education
- Security Due Diligence for 3rd party vendor management
- Ensure high standards for physical security.
- Maintain compliance against applicable cybersecurity requirements, laws, regulations, including but not limited to SAMA CSF, CRFR, MVC, KSA PDPL, UAE IAS and any additional KSA NCA applicable security standards.
- Maintain company ISO 27001 certification

- Develop a proactive culture of cybersecurity awareness among employees.
- Continuously monitor and patch any vulnerabilities in infrastructure and APIs.
- Improve threat intelligence by monitoring global and industry-specific threats.
- Incorporate cutting edge tools for threat detection and response.
- Transition to a behavior-based security model, implementing Zero Trust principles.
- Strengthen cloud security and containerization practices.

4.1.3 Alignment with Organizational and banking sector objectives

- **Support Business Continuity:** The cybersecurity strategy must align with the financial institution's overall goals of maintaining business continuity, ensuring service availability, and safeguarding sensitive customer information.
- **Compliance with Regulatory Requirements:**
 - **SAMA Compliance:** Align with the Saudi Arabian Monetary Authority's cybersecurity requirements, ensuring continuous monitoring, incident response readiness, and risk mitigation strategies.
 - **KSA PDPL:** Ensure compliance with the KSA Personal Data Protection Law, safeguarding customer data through encryption, proper data handling, and regular audits.
 - **NCA Requirements:** Ensure compliance with National Cybersecurity Authority (NCA) guidelines, adopting industry best practices for financial security.
- **Banking Sector Strategy Alignment:**
 - The strategy must also be in sync with the broader banking sector's security objectives, ensuring that the institution remains competitive, resilient, and adheres to sector-wide cybersecurity frameworks and initiatives (e.g., SAMA's Cybersecurity Framework).

4.1.4 Importance and Benefits of Cybersecurity for the Financial Institution

- **Security of Financial Assets:** Cybersecurity ensures the protection of financial transactions, customer data, and the institution's sensitive assets, reducing risks of financial losses and protecting the organization's reputation.
- **Regulatory Compliance:** Compliance with KSA's regulations, including SAMA (Saudi Arabian Monetary Authority) requirements: CSF, CRFR, MVC, the KSA PDPL (Personal Data Protection Law), and NCA (National Cybersecurity Authority) standards, enhances the institution's legal standing and avoids penalties.
- **Client Trust and Confidence:** A robust cybersecurity posture builds trust among customers, ensuring that their financial data and transactions are protected.
- **Operational Continuity:** Strong cybersecurity measures prevent business disruption from cyber-attacks, ensuring seamless banking services.
- **Competitive Advantage:** Demonstrating compliance with the highest cybersecurity standards can be a differentiator in the financial market, attracting security-conscious clients.

4.1.5 Anticipated Future State of Cybersecurity

- **Resilient Infrastructure:** The organization will evolve to a future state where cybersecurity is ingrained in all processes, ensuring rapid detection and response to emerging threats. The future will focus on building resilience against advanced persistent threats (APTs), zero-day vulnerabilities, and growing ransomware attacks.
- **Zero Trust Architecture:** Transitioning to a Zero Trust model, where access to systems and data is based on verification and continuous monitoring, ensuring that no entity is trusted by default.
- **AI and Machine Learning:** The institution will leverage AI-driven threat detection to identify and mitigate threats in real time, utilizing behavior-based analytics and advanced data monitoring.

- **Cloud and Container Security:** Strengthen the cloud-first architecture with advanced security measures, encryption, and monitoring to protect the financial institution's expanding cloud infrastructure.
- **Automated Threat Response:** Implement automation for incident response processes to ensure quick mitigation of detected threats, reducing manual intervention and improving response time.
- **Cybersecurity Awareness:** Develop a future where all employees, from executives to junior staff, are aware of and practice good cybersecurity hygiene, minimizing risks posed by human error.

4.1.6 Cybersecurity Initiatives and Timelines

This roadmap defines Lean Saudi's cybersecurity initiatives, tailored specifically to Saudi regulatory requirements, business growth plans, and the risk profile of regulated open banking services, in alignment with SAMA CSF ,KSA PDPL and other relevant regulations.

Initiative	Lean Saudi Scope and Enhancements	Target Timeline	Status (as of Dec 2025)
Enhanced DDoS Mitigation	Deploy multi-layer DDoS protection covering internet-facing APIs, customer portals, and Open Banking endpoints hosted in KSA. Scope includes volumetric, protocol, and application-layer attacks, with integration into SOC monitoring and incident response playbooks.	2025	Implemented - SEC-1939
GRC Tool Acquisition and Integration	Implement a GRC platform tailored for SAMA CSF and PDPL to manage risks, controls, evidence, incidents, and third-party oversight for Lean Saudi operations. The tool will support continuous compliance monitoring and regulatory reporting readiness.	2026	In Progress - SEC-1936
Public Trust Center	Establish a Lean Saudi Trust Center disclosing security posture, certifications, compliance status, incident communication principles, and data protection commitments, aligned with SAMA transparency expectations.	2025	Implemented - SEC-1945
SOC 2 Type II Certification	Achieve SOC 2 Type II certification scoped to Lean Saudi systems and services, demonstrating operational effectiveness of controls over time and supporting regulator and partner assurance.	2025	Completed - SEC-1990
SAMA CSF and PDPL	Execute structured gap assessments, remediation plans, and internal audits against SAMA CSF and	2025	Completed - SEC-1943

Maturity Program	PDPL, focusing on governance, risk management, identity, monitoring, and incident response.		
Zero Trust Security Model	Implement Zero Trust principles for Lean Saudi infrastructure, including strong identity verification, least privilege access, device trust, network segmentation, and continuous access evaluation for employees and third parties.	Q1-Q3 2026	In progress - SEC-1953 , SEC-1961 , SEC-1944 , SEC-1941 , SEC-1939
Red Teaming Assessment	Conduct red teaming exercises simulating real-world threat actor tactics, techniques, and procedures to evaluate the effectiveness of Lean Saudi's detection, response, and escalation capabilities across people, process, and technology	Q2 2026	Planned - SEC-2275
Bug Bounty Program	Establish a structured Bug Bounty Program to proactively identify, validate, and remediate security vulnerabilities in Lean Saudi's internet-facing applications, APIs, and digital services, complementing internal security testing activities.	Q1 2026	Planned - SEC-1952
Reduce RPO for our DR capabilities	Enhance disaster recovery architecture and processes to reduce Recovery Point Objective by improving backup frequency, replication mechanisms, and data integrity controls for critical Lean Saudi systems reassessments, and ongoing monitoring for vendors supporting Lean Saudi.	Q1 2026	Planned - SEC-1962
Refresh end-to-end Threat Modeling	Perform comprehensive threat modeling across Lean Saudi applications, APIs, cloud infrastructure, and data flows to identify potential attack paths, assess risks, and define mitigation controls aligned with the evolving threat landscape.	Q3 2026	Planned - SEC-2278
Automated Incident Response	Consider introducing SOAR capabilities to automate incident detection, containment, escalation, notification, and evidence collection, improving response speed and consistency for security incidents affecting Lean Saudi	Q3-Q4 2026	Planned - SEC-2277

	operations.		
--	-------------	--	--

Notes:

- The roadmap is reviewed at least annually by the GLRCC Committee and approved by senior management.
- Progress is tracked through defined milestones, KPIs, and risk indicators.
- Adjustments are made based on regulatory feedback, threat landscape evolution, and business expansion within KSA.

4.2 Information Security Strategy Key Components

4.2.1 Risk Management

Our cybersecurity strategy places high importance on the systematic identification, assessment, and management of risks to ensure the resilience of our information assets. Our risk management framework is designed to be proactive, enabling us to anticipate and respond to evolving cyber threats effectively. We conduct regular and comprehensive risk assessments, considering both internal and external factors that may impact our security posture.

These assessments inform the development of risk mitigation strategies tailored to the unique needs of our organization. Our approach involves continuous monitoring of key risk indicators, allowing us to swiftly identify and address emerging threats. We prioritize risks based on their potential impact on business operations and the confidentiality, integrity, and availability of sensitive information.

Clear communication channels and reporting mechanisms ensure that stakeholders are informed of risk profiles and mitigation efforts. By embedding risk management into our organizational culture, we not only strengthen our cybersecurity defenses but also foster a proactive and adaptive approach to safeguarding our digital assets.

See Lean Risk Management Framework for more details.

4.2.2 Governance and Compliance

At the core of our cybersecurity strategy is a robust governance framework that ensures the alignment of security initiatives with organizational objectives. Our governance structure is designed to facilitate effective decision-making, risk management, and accountability across all levels of the organization. Central to our approach is a commitment to regulatory compliance, encompassing adherence to industry standards, data protection regulations, and legal requirements.

Our governance model incorporates regular risk assessments to identify and prioritize potential threats, enabling the proactive development of mitigation strategies. We have established clear roles and responsibilities for cybersecurity stakeholders, fostering a culture of accountability and transparency. Through continuous monitoring and periodic evaluations, we ensure that our cybersecurity posture not only meets but exceeds regulatory expectations.

This integrated governance and compliance strategy reinforces our dedication to safeguarding information assets, maintaining the trust of stakeholders, and fortifying our resilience against evolving cyber threats.

4.2.3 Incident Response

We prioritize a proactive and well-defined approach to detect, contain, eradicate, and recover from security events. Clear roles and responsibilities are established, ensuring a rapid and coordinated response. Regular drills and scenario-based exercises enhance our team's readiness.

Continuous improvement is at the forefront, with post-incident analyses informing adjustments to our response procedures. Through this approach, we aim to minimize the impact of incidents, protect our systems and data, and swiftly return to normal operations.

4.2.4 Security Awareness Training

Our cybersecurity strategy emphasizes the importance of cultivating a security-aware culture within our organization. Regular and targeted security awareness training programs empower our personnel with the knowledge and skills needed to recognize and mitigate security threats.

We provide engaging and up-to-date content, covering best practices, social engineering awareness, and compliance requirements. The goal is to create a vigilant workforce capable of safeguarding sensitive information, reducing the risk of human error, and contributing to a resilient cybersecurity posture.

4.2.5 Security Tools and Technologies

We are Investing in cutting-edge security tools and technologies to mitigate threats and vulnerabilities:

- SAST, SCA tools
- DAST tools
- Interceptor tools
- Next Generation firewall
- IPS/IDS
- SIEM, XDR and SOC24x7
- DLP
- WAF
- Identity Provider
- MDM
- Anti-virus/antimalware
- Infrastructure Vulnerability Assessment
- Security awareness and training platform
- Phishing platform
- Advanced Security Coding training for engineers

4.2.6 Continuous Monitoring and Detection

Leveraging advanced technologies and proactive methodologies, we continuously scrutinize network activities, system logs, and user behaviors. Automated alerting systems coupled with vigilant analysis by our security team allow for rapid identification of potential threats.

Regular refinement of detection rules and continuous monitoring of key risk indicators ensure our ability to swiftly respond to emerging cybersecurity incidents. Through this vigilant approach, we enhance our situational awareness, fortify our defenses, and maintain a proactive stance against evolving threats.

We have 24x7 SOC services which provide continuous monitoring and detection across our platform and services.

4.2.7 Legal and Regulatory Landscape

Our cybersecurity strategy is underpinned by a commitment to compliance with industry standards and regulatory frameworks, notably ISO 27001 and SAMA cybersecurity requirements: CSF, NCA applicable standards, CRFR, MVC, KSA PDPL. We employ a comprehensive monitoring system that regularly assesses our practices against these standards. Continuous adherence to ISO 27001 ensures the

robustness of our Information Security Management System (ISMS), while compliance with SAMA requirements further safeguards our financial operations.

Regular audits, assessments, and internal reviews are conducted to validate our compliance status. By prioritizing a proactive approach to regulatory adherence, we not only meet the stringent requirements of ISO 27001 and SAMA but also instill confidence in our stakeholders regarding the security and integrity of our systems and data.

4.2.8 Measurement and performance

We have established Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) metrics to measure the effectiveness of the cybersecurity program as well as to be proactive with measuring certain risks level.

We continuously assess the performance of our cybersecurity program and strategy and adjust as needed to adapt to evolving threats and challenges.

For more details, see KPIs and KRIs page.

4.2.9 Third-Party Risk Management

Our cybersecurity strategy underscores the importance of a robust third-party risk management framework to safeguard our organization against external threats. We conduct thorough risk assessments, evaluating the security practices of our vendors and partners.

Our risk management approach extends to continuous monitoring, ensuring ongoing compliance with our security standards. Clear contractual requirements and regular communication channels facilitate the collaborative management of third-party risks.

Through these measures, we aim to fortify our cybersecurity defenses, protect sensitive information, and sustain a secure and resilient business ecosystem.

4.2.10 Continuous Education and Training

Our cybersecurity strategy prioritizes the continuous education and training of our personnel to cultivate a vigilant and security-conscious workforce. Regular and targeted training programs cover emerging threats, best practices, and compliance requirements.

Through ongoing education initiatives, we empower our employees to recognize and respond effectively to evolving cybersecurity challenges. By fostering a culture of continuous learning, we enhance our overall resilience against cyber threats, reduce the risk of human error, and reinforce our commitment to maintaining a secure digital environment.

4.2.11 Business Continuity Planning (BCP) and Disaster Recovery (DR)

As an integral component of our cybersecurity strategy, Lean Technologies places a strong emphasis on Business Continuity Planning (BCP) and Disaster Recovery (DR) to ensure the ongoing operational integrity and data resilience of our organization. Our BCP is aligned to the requirements of ISO 22301.

Our main focus of BCP is around ensuring that the availability of our core services is maintained and as such this is why we operate a cloud first approach to enhance our redundancy measures and increase our resilience.

4.2.12 Data Security and Privacy

At the center of our cybersecurity strategy is the commitment to the protection of sensitive data and the preservation of individual privacy. We employ a comprehensive data security framework that encompasses robust encryption measures, secure data handling procedures, and access controls.

Our strategy aligns with global data protection regulations, including GDPR, KSA PDPL and other relevant mandates, ensuring that personal and sensitive information is handled with the utmost care and compliance. Regular data classification exercises guide our efforts in prioritizing data protection measures based on the sensitivity and criticality of information.

Continuous monitoring and auditing mechanisms further strengthen our data security posture, allowing us to promptly identify and respond to any potential breaches. Privacy by design principles govern our development and deployment of systems, embedding privacy considerations at every stage of the information lifecycle. Through these measures, we not only protect the confidentiality and integrity of data but also uphold the trust of our customers, partners, and stakeholders in our commitment to data security and privacy.

4.2.13 Budget and Resources

Lean Security team has a dedicated security function with full time security professional with strong expertise in security testing, penetration testing, red teaming, and bug bounty hunting, including identification of vulnerabilities using modern techniques and adherence to the OWASP Top 10, MITRE attack framework.

Our cybersecurity strategy recognizes the critical importance of allocating adequate budget and resources to sustain a robust defense against evolving cyber threats. We prioritize investments in state-of-the-art security technologies, regular training programs, and ongoing monitoring capabilities. This strategic allocation ensures the availability of the necessary tools and expertise to safeguard our digital assets. We remain committed to the continual evaluation and adjustment of our budgetary and resource allocations, adapting to emerging threats and technological advancements to maintain a resilient cybersecurity posture.

Security staff performance evaluations will be conducted on a bi-yearly basis, with a mid-year review to assess progress and provide developmental feedback, followed by a comprehensive end-of-year review to evaluate overall performance, achievements, and goal alignment.

Industry Certifications achieved by Security team:

- Offensive Security Certification: OSCP
- Forensic investigation certification: CHFI
- Information Security and Risk Management Certifications: C|CISO, CISSP, CISM, CSSLP, CCSP, FIP4.

4.2.14 Network and Architecture Security

Our cybersecurity strategy prioritizes the fortification of our network infrastructure to ensure the confidentiality, integrity, and availability of our critical assets. We implement a multi-layered approach incorporating firewalls, intrusion detection/prevention systems, and secure configurations.

Regular network architecture reviews and vulnerability assessments bolster our defenses. Continuous monitoring of network traffic, coupled with swift response mechanisms, enables us to detect and thwart potential threats. Through these measures, we aim to maintain a resilient and secure network environment that aligns with industry best practices and safeguards against evolving cyber threats.

We perform regular network scanning using trusted Vulnerability Assessment tools

4.2.15 Endpoint Security

We place a strong emphasis on safeguarding endpoints, recognizing them as critical gateways to our digital environment. Endpoint protection measures, including robust antivirus solutions, encryption, and secure configuration standards, are implemented to mitigate risks.

Proactive patch management contributes to the resilience of our systems. Through these efforts, we aim to establish a secure endpoint landscape that effectively prevents, detects, and responds to potential security threats, ensuring the integrity of our digital infrastructure.

We have XDR capabilities through the deployment of SIEM agents on our organization endpoints. Furthermore, we use anti-malware and anti-virus capabilities from MacOS as well as VirusTotal services.

4.2.16 Secure Software Development

Our cybersecurity strategy integrates secure software development practices to ensure the resilience of our digital applications. Following industry best practices and leveraging secure coding standards, our development teams prioritize the identification and mitigation of security vulnerabilities throughout the software development lifecycle. Rigorous testing, code reviews, and adherence to secure coding guidelines contribute to the creation of robust and secure software.

We emphasize a proactive approach to cybersecurity in every phase of development, fostering a culture where security is not only a feature but an inherent aspect of our software development processes. Through these measures, we aim to deliver reliable and secure software solutions that meet the highest standards of cybersecurity.

4.2.17 Assets Security

Comprehensive asset inventory and classification processes are employed to identify and prioritize critical assets. Access controls, encryption, and physical security measures are implemented to protect the confidentiality, integrity, and availability of these assets.

Regular assessments and audits ensure that our security controls align with evolving threats and industry best practices. Through these measures, we aim to fortify our defenses, mitigate risks associated with asset compromise, and maintain the resilience of our organization in the face of cybersecurity challenges.

4.2.18 Identity and Access Management

We enforce robust Identity and Access Management (IAM) practices to ensure secure and controlled access to our systems and data. Through centralized user authentication, authorization protocols, and least privilege principles, we aim to prevent unauthorized access and protect sensitive information.

Regular reviews of user access rights and proactive management of identities contribute to a dynamic and secure IAM framework. Multi-factor authentication and strong password policies further enhance our defense against unauthorized access. By adopting a comprehensive IAM strategy, we fortify our cybersecurity posture, uphold the principle of least privilege, and safeguard our digital assets from unauthorized use.

4.3 Information Security Governance Framework

4.3.1 Governance Structure

4.3.1.1 Governance, Legal, Risk and Compliance Committee (GLRCC)

The GLRCC is made up of the following members:

- Richard Mico - Chief Legal Officer (Committee chair)
- Hisham Al-Falih - Chief Executive Officer (CEO and Director)
- Tewfik Cassis - Chief Product Officer (CPO)/ Chief Technology Officer (CTO)
- Dragos Dabija – Head of InfoSec
- Nasser Alshahrani - KSA Senior Security Manager
- Muna Alkhalaf - KSA Head of Compliance

- Mehdi Tazi - Chief Business Officer (CBO and UAE SEO)

Additional subcommittee members may be invited to attend GLRCC meetings from time to time, to offer ad hoc departmental input:

- Engineering
- Product
- People & Talent
- Finance
- Information Technology

Responsibilities

The GLRCC is entrusted with the following responsibilities:

- **Setting Strategic Objectives:** Collaboratively establish and communicate strategic cybersecurity objectives aligned with the overall business goals.
- **Policy Approval:** Review, approve, and oversee the implementation of cybersecurity policies, ensuring they align with regulatory requirements and industry best practices.
- **Risk Oversight:** Provide oversight on the organization's risk management strategy, ensuring that risks are identified, assessed, and appropriately mitigated.
- **Incident Response Planning:** Approve and review the incident response plan, ensuring the organization is well-prepared to respond to and recover from cybersecurity incidents.
- **Budget Approval:** Review and approve the cybersecurity budget, ensuring adequate resources for technology, training, and personnel to maintain an effective cybersecurity posture.

4.3.1.2 Security Committee

The Security Committee is a working group responsible for the day-to-day implementation of cybersecurity initiatives and operational activities.

Chairperson: Head of Infosec

Members:

- Staff Security Engineer (Application and Infrastructure Security)
- Security Engineer
- SOC Manager (outsourced)
- Security Analysts (representatives from the Security Operations Center)
- IT Security Managers

Responsibilities

The Security Committee is responsible for the following:

- **Implementation of Policies:** Execute and enforce the cybersecurity policies and standards established by the GLRCC.
- **Operational Oversight:** Oversee day-to-day security operations, including monitoring, incident response, and vulnerability management.
- **Technology Evaluation:** Assess and recommend security technologies, ensuring that they align with the organization's security requirements and objectives.
- **Continuous Improvement:** Drive continuous improvement initiatives based on feedback, incident analysis, and emerging threats.

4.3.2 Reporting Lines

4.3.2.1 Head of Information Security

- Direct Reporting: Directly reports to the CEO
- Responsibilities:
 - Provides regular updates on the organization's overall cybersecurity posture.
 - Presents cybersecurity strategies, initiatives, and challenges.
 - Reports on incidents, including their impact and resolution.
 - Support on security engineering

4.3.2.2 KSA Senior Security Manager

- Direct Reporting: Reports to CEO
- Responsibilities:
 - Reports on the implementation of security controls and risk mitigation efforts.
 - Ensure SAMA compliance
 - Support client and bank integration

4.3.2.3 Staff Security Engineer and Security Engineer (Application and Infrastructure Security)

- Direct Reporting: reports directly to Head of Information security, providing detailed insights into application and infrastructure security.
- Responsibilities:
 - Communicates technical details of security architectures and vulnerabilities.
 - Reports on the implementation of security controls and risk mitigation efforts.

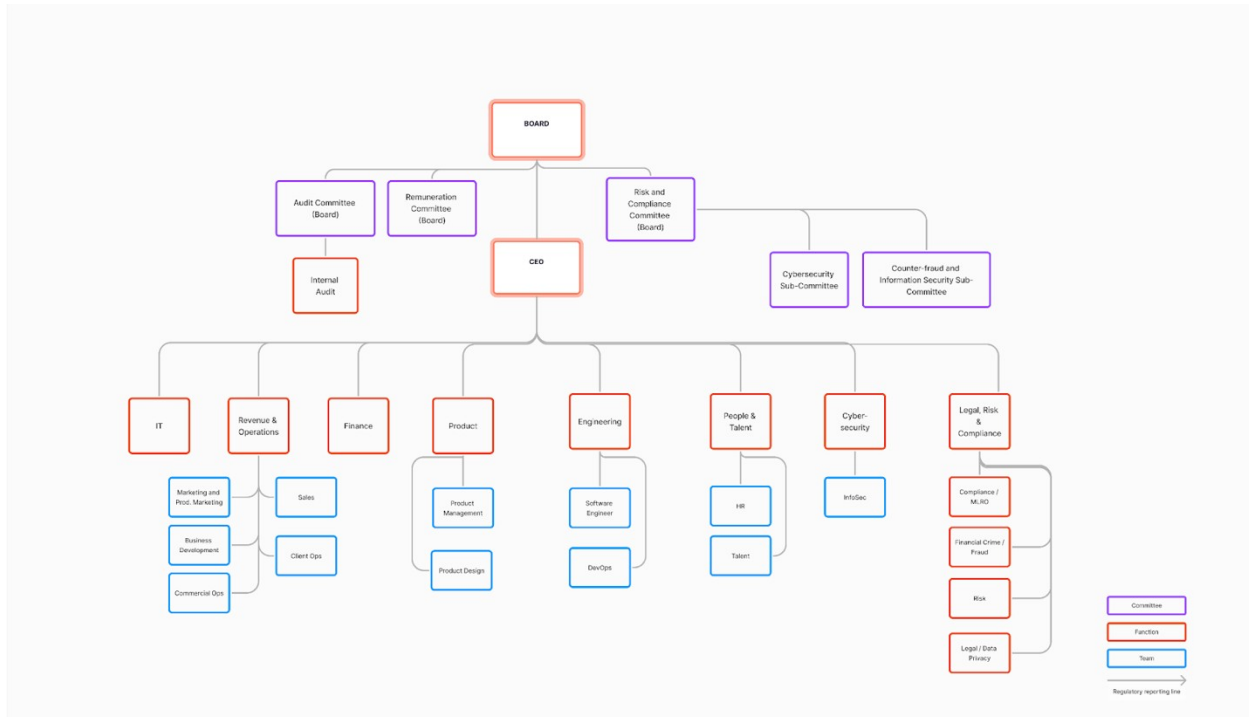
4.3.2.4 SOC Analysts

- Direct Reporting: Security Analysts report to the SOC Manager, who, in turn, communicates relevant information to the Head of Infosec.
- Responsibilities:
 - Provide updates on ongoing monitoring activities and incident triage.
 - Report on emerging threats and vulnerabilities.

4.3.2.5 Other Members

- Direct or Indirect Reporting: Other members of the GLRCC, including the CIO, CTO, CRO, CCO, and Legal Counsel, may receive direct or indirect reports from relevant cybersecurity leaders based on the nature of their involvement.

Lean Organization Structure



4.3.3 Communication Strategy and Protocols

4.3.3.1 Internal Communication Protocols

Effective communication within the organization is critical for maintaining a strong cybersecurity posture, ensuring alignment across leadership, and facilitating compliance with regulatory requirements. The communication framework is structured to enable transparent, secure, and timely information flow across governance bodies, operational teams, and relevant stakeholders.

4.3.3.1.1 Governance and Strategic Oversight

The Governance, Legal, Risk and Compliance Committee (GLRCC) serves as the primary decision-making body for cybersecurity and risk management. Communication within the GLRCC follows a structured approach:

- **Periodic Meetings and Reporting:** The GLRCC convenes regularly to discuss cybersecurity strategy, policy approvals, risk assessments, and budget allocations. Key updates from the Head of Information Security and other security leaders are presented to ensure visibility into risk posture and incident response readiness.
- **Incident and Risk Escalation:** Major cybersecurity risks, regulatory non-compliance issues, or critical security incidents must be escalated promptly to the GLRCC by the Security Committee or the Head of Information Security, ensuring swift decision-making and mitigation.
- **Regulatory and Compliance Alignment:** The KSA Senior Security Manager is responsible for ensuring that compliance with SAMA, NCA, and other regulatory requirements is effectively communicated and integrated into security strategies.

4.3.3.1.2 Operational and Tactical Security Communication

The Security Committee, led by the Head of Information Security, is responsible for the execution of cybersecurity initiatives. Communication within this committee ensures real-time operational awareness and response coordination:

- Security Operations Reporting: SOC Analysts and Security Engineers provide regular updates on incident trends, emerging threats, and vulnerabilities, which are consolidated by the SOC Manager and escalated to the Head of Information Security when necessary.
- Cross-functional Collaboration: Engineering, IT, and Product teams receive security updates related to application and infrastructure security, integrating security best practices into technology development.
- Security Control Implementation: Updates on new security technologies, improvements in security posture, and compliance efforts are shared between security teams and the CTO, ensuring security remains embedded in the technology landscape.

4.3.3.1.3 Reporting Structure and Communication Flow

- Head of Information Security reports to CEO, providing strategic cybersecurity updates, incident reports, and risk assessment, engineering security.
- KSA Senior Security Manager reports directly to the CEO, focusing on SAMA compliance, bank integrations, and regulatory security requirements.
- Security Engineers and Analysts report through structured chains (SOC Manager → Head of Infosec), ensuring technical and operational visibility across teams.
- GLRCC members, including Legal, Compliance, and Business leaders, receive periodic security updates, particularly when cybersecurity risks impact regulatory obligations or business continuity.

4.3.3.1.4 Employee Communication and Security Awareness

Effective internal communication extends beyond leadership and security teams to ensure that all employees are informed, engaged, and actively contributing to the organization's cybersecurity resilience. Employees play a critical role in maintaining security best practices and must be continuously educated on emerging threats and compliance requirements.

- Security Awareness Training: Regular training sessions, phishing simulations, and security workshops are conducted to enhance employee awareness of cybersecurity threats, regulatory obligations, and best practices for protecting company and customer data.
- Company-wide Security Updates: Periodic security bulletins and newsletters are distributed to keep employees informed about security policies, procedural updates, and key incidents or vulnerabilities relevant to their roles.
- Incident Reporting Mechanisms: Employees are encouraged to report security incidents, suspicious activities, or policy violations through the designated incident reporting channels (e.g., internal ticketing systems, security hotlines). A no-retaliation policy is enforced to promote proactive reporting.
- Access to Security Resources: Employees have access to security guidelines, policies, and FAQs via the company's intranet or knowledge base, ensuring that relevant information is readily available when needed.
- Cross-Departmental Collaboration: Security teams regularly engage with HR, Finance, and Operations to ensure security awareness is integrated into onboarding, policy acceptance, and compliance monitoring.

4.3.3.2 External Communication Protocols

The organization maintains structured communication with external stakeholders to ensure compliance, incident transparency, and operational coordination. Communication with these stakeholders follows predefined escalation paths, confidentiality controls, and regulatory reporting requirements.

4.3.3.2.1 Regulatory and Governmental Bodies

Communication with regulators is managed by designated security and compliance leaders, ensuring strict adherence to regulatory requirements.

- Central Bank of the UAE (CBUAE): Compliance-related security reporting, particularly regarding banking regulations and cybersecurity audits.
- Saudi Arabian Monetary Authority (SAMA): Regular reporting on cybersecurity risk assessments, incident disclosures, and adherence to SAMA-mandated security controls.
- National Cybersecurity Authority (NCA): Coordination on cybersecurity policies, reporting of critical incidents, and regulatory-driven security initiatives.
- SDAIA (Saudi Data and Artificial Intelligence Authority): Compliance with data governance, AI security policies, and national data regulations, ensuring privacy and security of financial data.

4.3.3.2.2 Clients and Business Partners

- Clients (Financial Institutions and Fintechs): Security teams provide clients with security assurance documentation, penetration test reports, and compliance attestations to establish trust in banking and fintech integrations.
- Incident Notification: In the event of a security breach impacting client data or services, a structured incident response communication plan ensures clients receive timely and accurate information, in compliance with regulatory notification timelines.

4.3.3.2.3 Crisis and Incident Communication

In the event of a major cybersecurity incident, the organization follows a Crisis Communication Plan, ensuring coordinated communication across internal and external stakeholders:

- Internal Escalation: Security teams immediately escalate incidents to the Security Committee and GLRCC, enabling executive-level decision-making.
- Regulatory Notifications: Compliance teams coordinate with regulators (SAMA, CBUAE, NCA) to meet reporting obligations.
- Client and Public Communication: If required, controlled messaging is released to affected clients, with legal and compliance teams ensuring adherence to disclosure policies while minimizing reputational risk.

By adhering to these structured communication protocols, the organization ensures a resilient, compliant, and well-coordinated approach to cybersecurity, risk management, and regulatory engagement.

5. Roles and Responsibilities

Governance, Legal, Risk and Compliance Committee (GLRCC)

Key responsibilities of the GLRCC are the following:

- To approve this document on at least an annual basis.

Head of Information Security

Key responsibilities of the Head of Information Security are the following:

- To develop and maintain this document and associated documents.
- To monitor the compliance with the principles of this document and report any deviations or breaches.

Internal Audit

Key responsibilities of Internal Audit are the following:

- To examine and evaluate the adequacy and effectiveness of Lean's policies, procedures and standards.
- To share the audit findings with the Head of Information Security to act on the observations and rectify any deviations or non-compliances.
- To conduct a follow up review and share any findings not resolved with GLRCC.

6. Procedures

N/A

7. Review and Updates

Lean's Information Security Strategy and Governance document is required to be updated annually and/or when significant changes that affect Lean's needs and operations have occurred (including after a major security incident).

The Head of Information Security is the owner of this document, responsible for ensuring that it is maintained up to date and committed to ensuring that this document is an accurate reflection of the applicable laws and regulations.

The document should be approved by the GLRCC. Any revision to this document shall specify the superseded version which shall be retained for future reference.

Document name: **CEO Resolution – Lean KSA
(Information Security Strategy
and Governance)**

Document ID: **30eda813-
e8f0-4814-9735-702048df1472**

Sender: **Lean Technologies (Legal)
<legal@leantech.me>**

Date of creation: **17/12/2025 15:42:43 AST**



Signers

Name	Team	Role	Status	Contact Method	Verification Method
Hisham Al-Falih	N/A	Signer	Signed	hisham@leantech.me	NA

Journal

Date	Action	Details
17/12/2025 15:42:43 AST	Document Created	Document created by [Lean Technologies (Legal)] [legal@leantech.me] [Device: 188.49.52.194]
17/12/2025 15:42:44 AST	Sent	Sent for signing from [Lean Technologies (Legal)] [legal@leantech.me] [Device: 188.49.52.194]
17/12/2025 15:56:57 AST	Viewed	Document viewed by [Hisham Al-Falih] [hisham@leantech.me] [Device: 188.49.52.194]
17/12/2025 15:57:30 AST	Signed	Document signed by [Hisham Al-Falih] [hisham@leantech.me] [Device: 188.49.52.194]
	Completed	

Date	Action	Details
17/12/2025 15:57:30 AST		The document has been completed, all parties have signed

Legal notice & Certification

This document has been electronically signed using Signit's digital signature platform. The electronic signatures applied to this document are legally binding and comply with applicable electronic signature regulations. All actions performed on this document have been securely logged and timestamped in the audit trail above. This audit trail serves as evidence of the document's integrity and the authenticity of the signatures. Any attempt to modify this document after signing will invalidate the signatures and can be detected through cryptographic verification.